Information Security Policies

Chapter 5 (Security Planning)

Principles of Information Security, Michael E., Whitman & Mattord, H. J., Cengage Learning, 2017.

Learning Objective

- Introduction to Security policy, standards, Practices and Procedures.
- Define what are information security policies
- Describe what an information security blueprint is, identify its major components, and explain how it supports the information security program.

Information Security Policies

- Organization's information security efforts will be effective only when incorporate with the organization's information security policy.
- Information security program begins with policy, standards, and practices, which are the foundation for the information security architecture.

Policies, Standard and Practices

- Policies are basis for all information security planning, design, and deployment.
- Policies direct how issues should be addressed and technologies should be used.
- Policies do not specify the proper operation of equipment or software—this information should be placed in the standards, procedures, and practices of users' manuals and systems documentation.
- Policy should never contradict law.

Policies

- **Definition:**
- Policy is a plan or course of action that conveys instructions from an organization's senior management to those who make decisions, take actions, and perform other duties.
- Policies are organizational laws in that they dictate acceptable and unacceptable behavior within the organization.
- what is right, what is wrong, what the penalties are for violating policy, and what the appeal process is?
- Policies must be:
  - Never conflict with laws
  - Stand up in court, if challenged
  - Be properly administered through dissemination and documented acceptance

Standard

- Detailed statements of what must be done to comply with policy.
- Required compliance
- Informal standard(are part of organization culture)
- Formal standard(Published, ratified from group or individuals)
- Practices, procedures, and guidelines explain how to comply with policies.

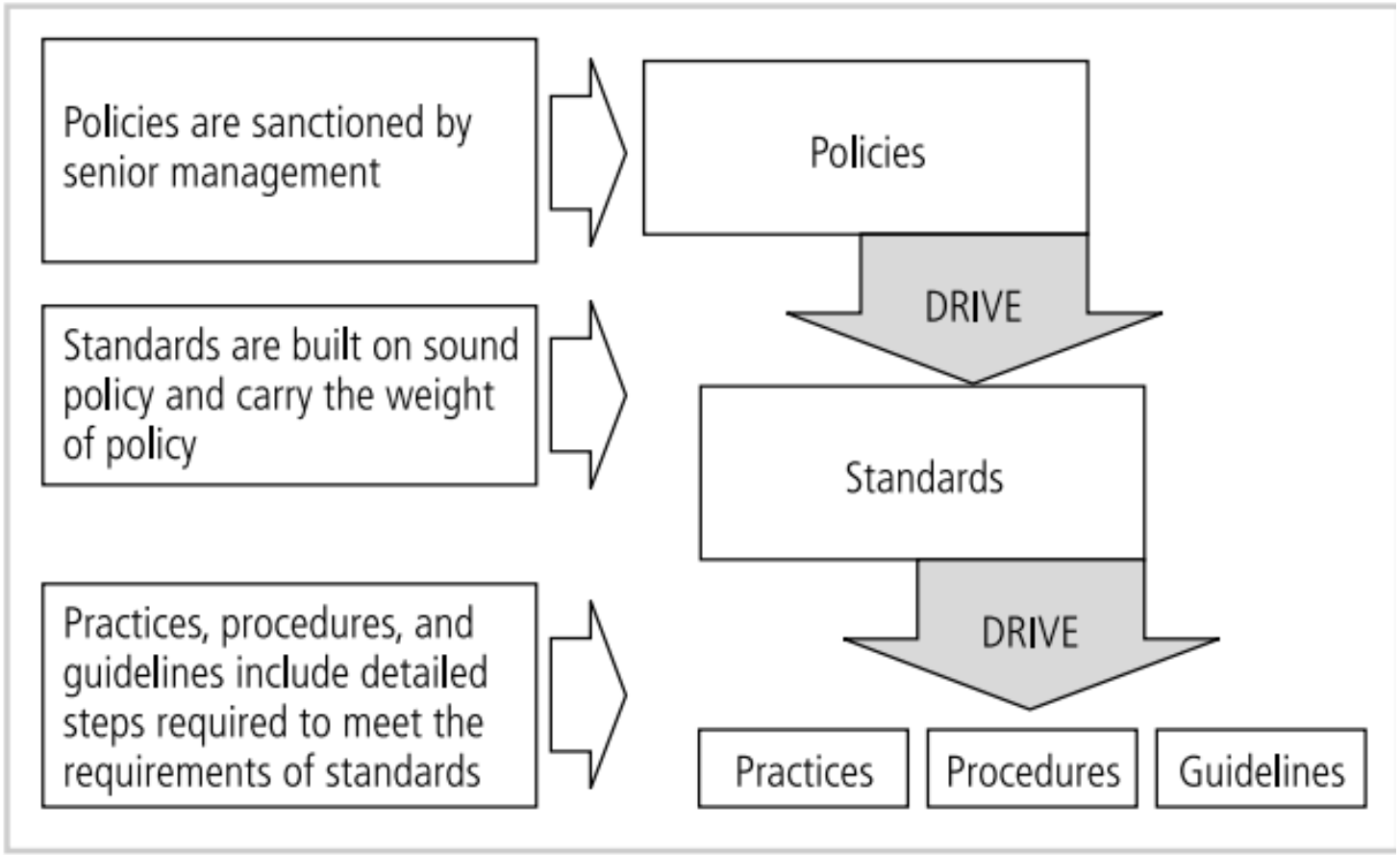

Figure 5-1 Policies, Standards, and Practices

Policies Requirement

- Policies are put in place to support an organization:
- Mission
- Vision
- Strategic planning

Mission: is a written statement of an organization's purpose OR objective.

Vision: is a written statement about the organization's goals where will the organization be in five years? In ten?

Strategic planning: is the process of moving the organization toward its vision.

Security Policies

- Term security policy depends on the context in which it is used.
- Governmental agencies view security policy in terms of national security and foreign affairs
- A security policy can also communicate a credit card agency's method for processing credit card numbers.
- A security policy is a set of rules that protect an organization's assets.

Information Security Policies

- Provides rules for the protection of the information assets of the organization.
- Management must define three types of security policy, according to the National Institute of Standards and Technology's (NIST) Special Publication 800-14 .
- 1. Enterprise information security policies
- 2. Issue-specific security policies
- 3. Systems-specific security policies

Criteria for effectiveness of IS policies

- Dissemination (distribution)
- Review (reading)
- Comprehension (understanding)
- Compliance (agreement)
- Uniform enforcement

Enterprise Information Security Policy (EISP)

- Known as general security policy, organizational security policy, IT security policy, or information security policy.
- Is based on mission, vision, and direction of the organization.
- The EISP is an executive level document drafted by or in cooperation with the chief information officer of the organization.
- Two to ten page long document.
- Guides the development, implementation, and management of the security program.
- Set the requirement must be accomplished by IS System.
- It defines the purpose, scope, constraints, and applicability of the security program.

Element of EISP

- EISP documents should include the following elements:
- Statement of Purpose
- Information Security Elements
- Need for Information Security
- Information Security Responsibilities and Roles
- Reference to Other Information Standards and Guidelines

Issue Specific Security Policy(ISSP)

- An organization executes various technologies and processes to support routine operations, it must instruct employees on the proper use of these technologies and processes.
- issue-specific security policy, or ISSP,

1. Addresses specific areas of technology
2. Requires frequent updates
3. Contains a statement on the organization's position on a specific issue.

Issue Specific Security Policy(ISSP)

- ISSP may cover the following topics:

1. E-mail
2. Use of the Internet
3. Specific configurations of computers to defend against worms and viruses
4. Prohibitions against hacking or testing organization security controls
5. Home use of company-owned computer equipment
6. Use of personal equipment on company Networks
7. Use of telecommunications technologies (fax and phone)
8. Use of photocopy equipment

Implementation Approach of ISSP

1. Independent ISSP documents, each tailored to a specific issue .
2. A single comprehensive ISSP document covering all issues.
3. A modular ISSP document that unifies policy creation and administration, while maintaining each specific issue's requirements.

System Specific Policies(SysSP)

- SysSPs : standards or procedures to be used when configuring or maintaining systems.
- Example:
  - SysSP might describe the configuration and operation of a network firewall.
  - This document could include a statement of managerial intent; guidance to network engineers on the selection, configuration, and operation of firewalls; and an access control list that defines levels of access for each authorized user.

System Specific Policies(SysSP)

- Can be Grouped into to separate categories:
  - Managerial guidance
  - Technical specifications
- Or can be combined into a single policy document.

System Specific Policies(SysSP)

- **Managerial Guidance SysSPs:**

Document is created by management to guide the implementation and configuration of technology as well as to address the behavior of people in the organization for security of information.

System Specific Policies(SysSP)

- Technical Specifications SysSPs:
- Manager work with a systems administrator to create managerial policy.
- The system administrator may in turn need to create a policy to implement the managerial.
- Convert management intent for the technical control into an enforceable technical approach.
- Two general methods of implementing such technical controls:
- **Access control lists**
- **Configuration rules**

Access Control List

- Who can use the system?
- What authorized users can access?
- When authorized users can access the system?
- Where authorized users can access the system from?

Configuration Rule

- Rule policies are the specific instructions that govern how a security system reacts to the data it receives.
- Rule-based policies are more specific to the operation of a system.

Policies Management

- Responsible Individual
- Schedule of Reviews
- Review Procedures and Practices

Information Security Blueprints

- Is the basis for the selection , Design and implementation of all security program elements including policy implementation, ongoing policy management, risk management programs, education and training programs, technological controls, and maintenance of the security program.
- Comprehensive plan to meet the organization's current and future information security needs.

Information Security Blueprints

- OR
- security framework, which is an outline of the overall information security strategy and a roadmap for planned changes to the information security environment of the organization.
- The blueprint specifies the tasks and the order in which they are to be accomplished.

Information Security Blueprints

- ISO/IEC 27002
- The ISO/IEC 27001: 2005 Plan-Do-Check-Act Cycle
- NIST SP 800-14 :Generally Accepted Principles and Practices for Securing Information Technology Systems
- Internet Engineering task force(IETF)
- Guide for Developing Security Plans for Federal Information Systems

Security Education, Training and Awareness

- The SETA program is the responsibility of the CISO .
- SETA Program is a control measure designed to reduce the incidences of accidental security breaches by employees.
- Purpose:

1. Improving awareness need to protect system resources.
2. Developing skills and knowledge so computer users can perform their jobs more securely.
3. Building in-depth knowledge, as needed, to design, implement, or operate security programs for organization.

	Education	Training	Awareness
Attribute	Why	How	What
Level	Insight	Knowledge	Information
Objective	Understanding	Skill	Exposure
Teaching	Theoretical instruction	Practical instruction	Media
method	• Discussion seminar	• Lecture	• Videos
	• Background reading	• Case study workshop	• Newsletters
	• Hands-on practice	• Posters	
Test measure	Essay (interpret learning)	Problem solving (apply learning)	• True or false • Multiple choice (identify learning)
Impact timeframe	Long term	Intermediate	Short term

Table 5-10 Comparative Framework of SETA (from NIST SP800-12[22])

Questions